Memo for the steering committee

This document is meant to function as a meeting reference as well as a memorandum.

What is going on:

The September report may look grim and overwhelming at first glance, but it is misleading in many ways. The most important problem is that it considers all vulnerabilities more or less equally important when that is not the case. It also gives an impression of there being more distinct problems than is actually the case. With more time I could create tools that should help sort through the noisy scanner data to find what is important and what isn't.

The decisions:

1.
The adoption of an up to date formal process for prioritizing security findings. The September report uses an outdated paradigm for prioritization. There are two options I present as sensible. The first is to use the prioritization scheme I have devised, which I believe will be a good match for Norvik's needs, and is easily implementable today. We can also adopt the generally accepted SSVC (Stakeholder-Specific Vulnerability Categorization) framework published by CISA (the American Cybersecurity and Infrastructure Security Agency), which will involve more work in its implementation.

2.
The adoption of a better way to count mean-time-to-resolve and changing the remediation deadlines. I suggest [I have not done the math but if I had done the math I would give a proposal here]. This will avoid counting time where vendors disclose vulnerabilities but no fix is available for the vulnerability yet, as well as properly account for long-open findings that have not been resolved yet.

3.
The adoption of new key metrics and discarding of bad ones. The important change here is considering the number or percentage of unscanned assets, and dropping the dashboard count of vulnerabilities and replacing it with a count of fixes to apply.

4.
The exception process has to be updated and reworked. One big flaw of the current process is that a team lead can request an exception and approve it themselves without needing to ask anyone else for permission. Beyond that there are many exceptions that have aged out but are still listed as active.

Some technical stuff:

My prioritization scheme computes a priority number for each vulnerability dependent on how critical it is to Norvik's business, if the computer is directly accessible from the public internet, if the vulnerability is known to be exploited in the wild, how severe the most problematic exploit is, and lastly using the estimated risk-of-exploitation as a tie-breaker. SSVC involves categorizing each problem in a class of action that it requires, based on some criteria of the vulnerability itself.
My current prioritization scheme suggests the following important actions to take:
1. Many store network devices run FortiOS and have not been updated with appropriate security updates. This is true both of business critical network devices and high importance network devices. These are generally very vulnerable attack surfaces as they are internet-facing.
2. Continuing windows server updates. This is not news, and is an artifact of insufficient data cleaning. They are very important, but mostly these show up in a way higher proportion than they actually require action. I must stress that one should install cumulative windows security updates religiously, I just expect that this is already being done.
3. 7-zip updates on headquarters machines and laptops. This is the kind of software no one updates by themselves, and there are in fact extremely critical vulnerabilities that need patching. I suggest updating these by a centralized method or autoupdate daemon.
4. Some of the DMZ servers running red hat enterprise linux have some security updates that the scanner thinks are lacking. This is a very important problem, but it may already be resolved, as the Red Hat team backports security fixes to older versions of Red Hat linux. It will need some investigation to determine whether this is a false positive or not.

For extremely important security issues for teams that have ample IT and software engineering staff, it may be necessary to find a workaround to a security vulnerability before a fix comes from the software vendor. But this can hardly be asked of store owners.

There are some anomalies that showed up once I tried finding out what assets in the CMDB the scanner can't see. The security team is investigating them. The important ones to know are that many of the store servers in Norway have their scans fail, and a smattering of store back-office computers do not have scanning agents installed.